

# **SIMATS ENGINEERING**

## **ASSESSMENT TOOL 3**

**COURSE CODE: CSA5115**

**COURSE NAME: Cryptography and Network Security**

### **COURSE OUTCOME COVERED**

**CO4:** *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

*Assessment Tool Weightage: 10%*

**QUESTIONS: 5**

**TOTAL MARKS: 25**

### **Annexure A Comparative Analysis**

#### ***Code of Conduct:***

*I M Nishanth (192511154) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of the student: M Nishanth**

***Annexure A***  
***Comparative Analysis***

1. Compare Authentication Header (AH) and Encapsulating Security Payload (ESP) in IPSec with respect to security services, performance overhead, and suitability for different network scenarios. Analyze which is more appropriate for a VPN deployment.
2. Compare transport mode and tunnel mode in IPSec architecture. Evaluate their effectiveness in securing host-to-host versus network-to-network communication.
3. Perform a comparative analysis of Pretty Good Privacy (PGP) and S/MIME in terms of key management, trust models, scalability, and enterprise usability. Recommend the most suitable approach for a corporate email system.
4. Compare rule-based and machine learning-based email spam detection techniques. Analyze their effectiveness in handling evolving spam patterns and minimizing false positives.
5. Compare manual key management and automated key management (e.g., using IKE) in IPSec. Evaluate their impact on security, scalability, and operational complexity in large organizations.

# SIMATS ENGINEERING

## ASSESSMENT TOOL 3

### Question 1: Authentication Header (AH) vs Encapsulating Security Payload (ESP)

#### 1.1 Scope of the Comparison

IPSec provides network-layer security through two core protocols, AH and ESP. Both operate on IP datagrams but differ fundamentally in the security services they provide, the overhead they impose, and the deployment scenarios they suit. This comparison covers security services, performance overhead, and suitability for VPN and other network contexts.

#### 1.2 Comparative Analysis

| Aspect                 | Authentication Header (AH)                                                                 | Encapsulating Security Payload (ESP)                                                  |
|------------------------|--------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Confidentiality        | Not provided — AH does not encrypt payload data                                            | Provided — encrypts payload using symmetric algorithms (AES, 3DES)                    |
| Data Integrity         | Provided — covers entire IP packet, including outer header fields (except mutable fields)  | Provided — covers ESP header, payload, and trailer, but not the outer IP header       |
| Authentication         | Provided (origin authentication of sender)                                                 | Provided (optional, via ICV in ESP trailer)                                           |
| Anti-Replay Protection | Yes, via sequence numbers                                                                  | Yes, via sequence numbers                                                             |
| Protocol Number        | IP Protocol 51                                                                             | IP Protocol 50                                                                        |
| NAT Traversal          | Poor — breaks under NAT because it authenticates the IP header, and NAT modifies addresses | Better — supports NAT-T (UDP encapsulation) since header fields are not authenticated |
| Performance Overhead   | Lower — only hashing (HMAC) is performed, no encryption                                    | Higher — both encryption and optional hashing are performed                           |
| Header Protection      | Protects most of the outer IP header                                                       | Does not protect the outer IP header                                                  |
| Typical Use Case       | Scenarios needing integrity/authenticity only, e.g., internal trusted networks             | Scenarios needing confidentiality, e.g., VPNs over the public Internet                |

#### 1.3 Critical Analysis and Recommendation

AH is well suited where the requirement is strictly to guarantee that packets have not been altered and genuinely originate from the claimed sender — for example, securing routing protocol updates on a private backbone where confidentiality is not a concern. However, because AH authenticates the outer IP header itself, it is largely incompatible with Network Address Translation, which is extremely common in modern real-world deployments (home routers, corporate NAT gateways, cloud NAT). This alone makes AH impractical for most Internet-facing VPNs today.

ESP, by contrast, provides confidentiality in addition to integrity and authentication, and its NAT-Traversal (NAT-T) extension allows it to be encapsulated in UDP so it can pass through NAT devices. Since a VPN's primary purpose is to protect data confidentiality and integrity across an untrusted public network (and frequently across NAT boundaries), ESP is the more appropriate and, in practice, the almost universally chosen protocol for VPN deployments — including IPSec-based site-to-site and remote-access VPNs. AH's use has consequently declined and is now largely restricted to niche scenarios where encryption is unnecessary or even undesirable (e.g., regulatory environments that require traffic inspection).

**Conclusion:** For a VPN deployment, ESP is the more appropriate protocol because it provides confidentiality alongside integrity and authentication, and its NAT-T support makes it deployable in realistic network topologies where AH would fail.

## Question 2: Transport Mode vs Tunnel Mode in IPSec

### 2.1 Scope of the Comparison

IPSec can operate in two modes that determine how the original IP packet is protected and repackaged. The comparison below evaluates their structure, protection scope, and effectiveness for host-to-host versus network-to-network (gateway-to-gateway) communication.

### 2.2 Comparative Analysis

| Aspect                   | Transport Mode                                                                                              | Tunnel Mode                                                                                                          |
|--------------------------|-------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Packet Structure         | Only the payload (transport-layer segment) is encrypted/authenticated; original IP header is retained       | The entire original IP packet (header + payload) is encrypted/authenticated and encapsulated inside a new IP header  |
| Header Exposure          | Original source/destination IP addresses remain visible                                                     | Original IP addresses are hidden inside the encrypted inner packet; only the new outer gateway addresses are visible |
| Overhead                 | Lower — only one IP header exists                                                                           | Higher — an additional outer IP header is added                                                                      |
| Typical Endpoints        | Host-to-host (both ends run IPSec, e.g., two servers)                                                       | Gateway-to-gateway or host-to-gateway (e.g., two firewalls/routers)                                                  |
| Primary Use Case         | Securing direct communication between two specific machines, e.g., a management session between two servers | Site-to-site VPNs connecting entire networks, and remote-access VPNs where a client tunnels into a corporate gateway |
| Scalability for Networks | Poor — does not conceal internal network topology, not designed to protect traffic for many hosts at once   | Good — a single gateway pair can protect traffic for all hosts behind them without configuring IPSec on each host    |

| Aspect                      | Transport Mode                             | Tunnel Mode                                                 |
|-----------------------------|--------------------------------------------|-------------------------------------------------------------|
| Confidentiality of Topology | No — internal addressing scheme is exposed | Yes — internal addressing is hidden from the public network |

## 2.3 Critical Analysis and Recommendation

Transport mode is efficient and appropriate when both communicating endpoints themselves implement IPsec and need to protect only the data they exchange — for instance, securing traffic between two specific application servers. Because it leaves the original IP header intact, it is not designed to hide network topology, and it requires IPsec configuration on every host that needs protection, which does not scale well when many hosts must communicate securely across an untrusted network.

Tunnel mode addresses exactly this network-to-network requirement: by wrapping the entire original packet inside a new one, gateways at each site can protect all traffic between two networks without any IPsec configuration on the individual internal hosts, and the internal addressing scheme stays hidden from anyone observing the public path. This is why virtually all site-to-site VPNs, and most remote-access VPN clients connecting to a corporate gateway, use tunnel mode.

Conclusion: Transport mode is more effective for direct host-to-host protection between IPsec-aware endpoints, while tunnel mode is markedly more effective — and the practical standard — for network-to-network communication, since it scales to many hosts, requires no client-side IPsec configuration on internal machines, and conceals internal topology.

## Question 3: PGP vs S/MIME

### 3.1 Scope of the Comparison

PGP and S/MIME are the two dominant standards for securing email through encryption and digital signatures. They differ chiefly in how trust is established and how keys are managed, which has direct implications for scalability and enterprise usability.

### 3.2 Comparative Analysis

| Aspect           | PGP (Pretty Good Privacy)                                                                   | S/MIME                                                                                                      |
|------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Trust Model      | Web of Trust — decentralized; users sign each other's public keys to vouch for authenticity | Hierarchical PKI — centralized; trust is rooted in Certificate Authorities (CAs)                            |
| Key Management   | Users generate and distribute their own key pairs; no mandatory central authority           | Requires digital certificates issued and managed by a trusted CA (X.509 certificates)                       |
| Key Distribution | Via public key servers, personal exchange, or key-signing parties                           | Via CA-issued certificates, often integrated with organizational directory services (LDAP/Active Directory) |
| Scalability      | Harder to scale in large                                                                    | Scales well in enterprises — a single                                                                       |

| Aspect                         | PGP (Pretty Good Privacy)                                                                   | S/MIME                                                                                                            |
|--------------------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
|                                | organizations — trust paths can be inconsistent or missing between unrelated users          | organizational CA (or a small trusted CA hierarchy) can issue and validate certificates for all employees         |
| Revocation                     | Key revocation certificates, but propagation across the web of trust can be slow/incomplete | Standardized revocation via CRLs or OCSP, tightly integrated with PKI infrastructure                              |
| Ease of Enterprise Integration | Limited native support in major corporate mail clients without add-ons                      | Native support in most enterprise mail clients (Outlook, etc.) and integrates cleanly with existing corporate PKI |
| Administrative Overhead        | Lower centralized overhead, but higher burden on individual users to manage trust           | Higher centralized overhead (running/maintaining a CA), but lower burden on individual end users                  |
| Typical Users                  | Individuals, journalists, open-source/security communities, privacy-focused users           | Corporations, government agencies, regulated industries needing auditable, centrally managed trust                |

### 3.3 Critical Analysis and Recommendation

PGP's Web of Trust is appealing for its decentralization — no single authority can be compromised to undermine the entire system — but that same property makes it difficult to guarantee that every pair of employees in a large organization has a valid trust path to one another, especially as staff join, leave, and change roles. Verifying and maintaining that trust largely falls on individual users, which is impractical to enforce consistently at enterprise scale.

S/MIME's reliance on a hierarchical PKI, rooted in one or a few CAs the organization already trusts (often the same CA infrastructure used for other services), maps naturally onto how enterprises are structured: centralized IT can issue, renew, and revoke certificates for all staff, integrate certificate lookup with existing directories, and produce the audit trails that regulated industries require. This centralized administration is more overhead for IT, but it removes the burden from end users and delivers consistent, predictable trust across the whole organization.

Conclusion: For a corporate email system, S/MIME is the more suitable approach. Its PKI-based, centrally managed trust model aligns with enterprise scalability and administrative needs, whereas PGP's Web of Trust is better suited to individual or community use where decentralization is valued over centralized manageability.

## Question 4: Rule-Based vs Machine Learning-Based Spam Detection

### 4.1 Scope of the Comparison

Email spam filters generally fall into two categories: rule-based systems that match messages against predefined patterns, and machine-learning-based systems that learn statistical patterns from labeled data. This comparison evaluates both against evolving spam patterns and false-positive rates.

## 4.2 Comparative Analysis

| Aspect                        | Rule-Based Detection                                                                                 | Machine Learning-Based Detection                                                                                                     |
|-------------------------------|------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Detection Mechanism           | Predefined rules — keyword blacklists, header checks, regex patterns, sender/domain blocklists       | Statistical/pattern learning — models (e.g., Naive Bayes, SVM, neural networks) trained on labeled spam/ham datasets                 |
| Adaptability to New Spam      | Low — must be manually updated whenever spammers change tactics                                      | High — can be retrained on new data and can generalize to previously unseen patterns                                                 |
| False Positive Rate           | Can be high if rules are too broad, or low if very narrowly tuned — but tuning is manual and brittle | Generally lower and more adaptive over time as the model learns finer-grained distinguishing features                                |
| Maintenance Effort            | High — requires continuous manual rule authoring by administrators                                   | Moderate — requires periodic retraining and quality-labeled data, but adapts with less manual intervention                           |
| Transparency / Explainability | High — it is easy to see exactly which rule triggered a block                                        | Lower — particularly for complex models, decisions can be harder to interpret                                                        |
| Resource Requirements         | Low computational cost                                                                               | Higher computational cost for training; inference cost varies by model                                                               |
| Resilience to Evasion         | Weak — spammers can trivially bypass known rules (e.g., misspelling trigger words)                   | Stronger — can detect subtler statistical signals that survive superficial obfuscation, though adversarial evasion is still possible |

## 4.3 Critical Analysis and Recommendation

Rule-based systems offer transparency and predictability — administrators know precisely why a message was flagged, which is valuable for auditing and quick manual correction. Their fundamental weakness is that spam is an adversarial and constantly evolving problem: spammers actively probe and circumvent known rules (e.g., character substitution, image-based spam), and every countermeasure requires a human to notice the new pattern and hand-craft a rule, which lags behind attackers.

Machine learning-based detection is far better suited to this evolving threat landscape because it learns generalizable statistical signals (word co-occurrence, sender behavior, structural features) rather than exact patterns, allowing it to catch variants of spam it has not explicitly seen before, provided it is retrained regularly on fresh labeled data. Its main risks are a dependence on data quality (poor or stale training data degrades accuracy) and reduced explainability, which can complicate manual review of edge cases.

Conclusion: In practice, the most effective real-world spam filters (e.g., in major email providers) combine both approaches — fast, transparent rule-based filters for obvious cases and known bad senders, layered with ML-based classifiers for nuanced and evolving patterns. Where only one approach must be chosen, machine learning-based detection is more effective at handling evolving spam and

minimizing false positives over time, because it adapts continuously rather than depending on manual rule maintenance.

## Question 5: Manual vs Automated Key Management (IKE) in IPSec

### 5.1 Scope of the Comparison

IPSec Security Associations require cryptographic keys, which can be provisioned manually by an administrator or negotiated automatically using the Internet Key Exchange (IKE) protocol. This comparison evaluates their impact on security, scalability, and operational complexity, particularly in large organizations.

### 5.2 Comparative Analysis

| Aspect                 | Manual Key Management                                                                                                         | Automated Key Management (IKE)                                                                                         |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| Key Configuration      | Administrator manually configures and distributes pre-shared keys on each device                                              | Keys are dynamically negotiated between peers using IKE (Phase 1 and Phase 2 exchanges)                                |
| Key Rotation           | Rare in practice — rotating keys requires manually reconfiguring every device, so keys often remain static for long periods   | Automatic periodic re-keying, reducing the window of exposure if a key is compromised                                  |
| Security               | Weaker over time — long-lived static keys increase risk if leaked or brute-forced; also prone to human error in distribution  | Stronger — supports Perfect Forward Secrecy (via Diffie-Hellman), authenticated negotiation, and frequent key refresh  |
| Scalability            | Poor — the number of manual key pairs grows roughly quadratically with the number of peers (an $O(n^2)$ distribution problem) | Good — IKE dynamically negotiates keys per session, so it scales to many peers without pre-distributing every key pair |
| Operational Complexity | Simple to understand initially, but becomes very labor-intensive and error-prone as the network grows                         | Higher initial setup and protocol complexity, but far lower ongoing administrative burden at scale                     |
| Suitability            | Small, static networks with very few IPSec peers                                                                              | Large, dynamic organizations with many peers, remote users, or frequently changing topology                            |
| Failure Recovery       | Manual intervention needed to replace a compromised key across all affected devices                                           | Automated renegotiation limits blast radius and speeds recovery                                                        |

### 5.3 Critical Analysis and Recommendation

Manual key management can be adequate for a very small deployment — for example, a permanent link between two branch offices where a network engineer can safely configure a handful of static keys once. Its transparency (an administrator knows exactly which key is where) is an advantage at small scale, but this same manual process becomes a serious liability as the organization grows: keys are rarely rotated



because doing so is operationally painful, increasing exposure time if a key is ever compromised, and the number of key pairs needed grows rapidly as more peers are added, making distribution error-prone.

Automated key management via IKE was designed precisely to solve these problems. It negotiates fresh session keys automatically (typically using Diffie-Hellman key exchange for Perfect Forward Secrecy), authenticates peers dynamically, and re-keys periodically without administrator intervention, which both strengthens security posture and removes the linear/quadratic administrative burden of manual distribution. The trade-off is a more complex protocol (IKE Phase 1/Phase 2 negotiation) that requires correct initial configuration and a working PKI or pre-shared authentication mechanism to bootstrap trust.

Conclusion: For large organizations, automated key management using IKE is clearly superior. It offers stronger security through frequent re-keying and forward secrecy, and it scales to large numbers of peers without the administrative overhead and rotation problems inherent to manual key management, which remains suitable only for very small, static deployments.

## References

- Stallings, W. – Cryptography and Network Security: Principles and Practice.
- Forouzan, B. A. – Cryptography and Network Security.
- RFC 4301 – Security Architecture for the Internet Protocol.
- RFC 4302 – IP Authentication Header (AH).
- RFC 4303 – IP Encapsulating Security Payload (ESP).
- RFC 7296 – Internet Key Exchange Protocol Version 2 (IKEv2).
- RFC 5751 – Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 3.2.
- RFC 4880 – OpenPGP Message

## RUBRICS FOR CALCULATION:

| Criteria                | Weightage (%) | Level 4 (Exemplary)                                                           | Level 3 (Proficient)                            | Level 2 (Developing)                       | Level 1 (Beginning)                      |
|-------------------------|---------------|-------------------------------------------------------------------------------|-------------------------------------------------|--------------------------------------------|------------------------------------------|
| Scope of Items          | 20%           | Selects highly relevant items with clear scope and justification              | Selects appropriate items with minor gaps       | Selection is limited or partially relevant | Items are unclear or not relevant        |
| Comparison Depth        | 25%           | Provides detailed and comprehensive comparison across multiple aspects        | Provides adequate comparison with some depth    | Limited comparison with few aspects        | Very minimal or no comparison            |
| Use of Evidence         | 20%           | Supports comparison with accurate data, examples, or references               | Uses some supporting evidence with minor gaps   | Limited or weak supporting evidence        | No supporting evidence provided          |
| Critical Thinking       | 20%           | Demonstrates strong critical thinking with clear interpretation and reasoning | Shows reasonable interpretation with minor gaps | Basic interpretation; lacks depth          | No meaningful interpretation             |
| Clarity of Presentation | 15%           | Well-organized, clear, and logically structured presentation                  | Generally clear with minor issues               | Somewhat unclear or poorly structured      | Disorganized and difficult to understand |